

Data Leak Worksheet

Incident summary:

A sales manager shared access to a folder of internal-only documents with their team during a meeting. The folder contained files associated with a new product that has not been publicly announced. It also included customer analytics and promotional materials. After the meeting, the manager did not revoke access to the internal folder, but warned the team to wait for approval before sharing the promotional materials with others.

During a video call with a business partner, a member of the sales team forgot the warning from their manager. The sales representative intended to share a link to the promotional materials so that the business partner could circulate the materials to their customers. However, the sales representative accidentally shared a link to the internal folder instead. Later, the business partner posted the link on their company's social media page assuming that it was the promotional materials.

Control	Least privilege
Issue(s)	The data leak occurred because the internal folder's access permissions were not strictly limited to internal employees. The manager failed to revoke temporary access after the meeting, and external link sharing was not proactively disabled for sensitive directories.
Review	NIST SP 800-53: AC-6 outlines guidelines for implementing the principle of least privilege to ensure data confidentiality and prevent leaks. It provides specific control enhancements to restrict user access solely to the minimum necessary for their specific business functions.
Recommendation(s)	• Restrict access to sensitive resources based on strictly defined user roles. • Configure automatic access revocation for temporary permissions (e.g., post-meeting). • Disable external sharing capabilities for internal-only directories by default. • Regularly audit user privileges and monitor access logs.

Justification

Implementing NIST SP 800-53: AC-6 controls enforces strict access boundaries. By restricting external sharing and automating access revocation, the organization minimizes the risk of human error leading to data exposure. Regular audits ensure excessive permissions are identified and remediated promptly, securing internal data processing.